Incident Management & Response Policy

Cosmaneura, Inc. — Cosma application

Version: 1.0 **Effective:** 2026-04-20 **Next review:** 2027-04-20 **Owner:** CTO / Incident Commander

1. Purpose

This policy defines how Cosmaneura detects, responds to, communicates about, and learns from security and availability incidents affecting the Cosma application. Its goals are to minimize customer impact, preserve evidence, meet legal notification obligations, and drive continuous improvement.

2. Scope & definitions

An **incident** is any event that adversely affects, or is likely to adversely affect, the confidentiality, integrity, or availability of Cosma or of customer data. This includes — but is not limited to — credential compromise, unauthorized data access, malware on production systems, significant service degradation, and data loss.

3. Severity levels

Level	Definition	Target response
P0 — Critical	Confirmed unauthorized access to customer data, active data exfiltration, or total production outage.	Acknowledge within 15 minutes; continuous on-call engagement until contained.
P1 — High	Suspected security compromise; major partial outage affecting many customers; loss of a critical integration (Zoom, recording pipeline).	Acknowledge within 1 hour; active work during business hours with on-call coverage.
P2 — Medium	Contained vulnerability with no evidence of exploitation; degraded performance affecting a subset of users.	Acknowledge within 1 business day.
P3 — Low	Informational findings; non-user-facing anomalies.	Acknowledge within 5 business days.

4. Detection sources

- **Sentry** — real-time error and performance alerting on backend and frontend.
- **Structured application logs** — `structlog` JSON logs, inspected during triage and postmortem.
- **Health checks** — FastAPI `/healthcheck` endpoint and Celery health worker.
- **Dependabot / GitHub security advisories** — vulnerability disclosures in third-party dependencies.
- **Provider notifications** — security advisories from Zoom, Azure, Clerk, Recall.ai, AssemblyAI, etc.
- **User or researcher reports** — sent to `dev@cosmaneura.com`.

5. Response workflow

1. **Detect & declare.** The first responder classifies severity and, for P0/P1, declares an incident and assumes the Incident Commander role until handed off.
2. **Assemble.** The Commander pulls in necessary engineers; a shared timeline document is opened (used later for the postmortem).
3. **Contain.** Stop the bleed: rotate credentials, revoke tokens, block IPs, roll back deploys, or scale up capacity as appropriate.
4. **Eradicate.** Identify the root cause and remove it from production.
5. **Recover.** Restore service to full function and verify via monitoring.
6. **Communicate.** Status updates to affected customers per §6.
7. **Postmortem.** Within 7 business days the Commander publishes a blameless postmortem covering impact, timeline, root cause, and concrete follow-up actions, each with an owner and a due date.

6. Customer & regulator notification

- **Security incidents affecting customer data:** affected customers are notified without undue delay and **within 72 hours** of becoming aware of the incident, consistent with GDPR Article 33 and HIPAA Breach Notification expectations.
- **Zoom Marketplace obligations:** Zoom is notified through the Marketplace security contact process whenever an incident affects the security of the Zoom integration or the data obtained through it.
- **Regulatory reporting:** applicable regulators and business associates are notified as required by the governing law or BAA.

7. Roles during an incident

Role	Responsibility
Incident Commander	Owns overall response, declares severity, coordinates communications.
Technical Lead	Drives containment, eradication, and recovery.
Communications Lead	Drafts customer, Zoom, and (if applicable) regulator notifications.
Scribe	Maintains the shared timeline document.

In a small-team incident the Commander may hold multiple roles, but the Commander role itself is always explicitly named.

8. Evidence preservation

During P0 and P1 incidents, system logs, Sentry events, and affected database snapshots are preserved for at least 180 days. Access is limited to personnel involved in response and (where applicable) to outside counsel or forensic investigators.

9. Testing & continuous improvement

The response workflow is exercised at least annually through a tabletop exercise. Each postmortem generates tracked follow-up actions, reviewed at the next policy review.

10. Contact

To report a security incident or suspected incident: `dev@cosmaneura.com`. We will acknowledge reports within one business day; urgent P0/P1 reports should be clearly flagged in the subject line.